



Secretless Multi-Cloud Authentication with Workload Identity for DevSecOps Pipelines

A policy-driven framework using OpenID Connect and workload identity federation to eliminate long-lived credentials from cross-cloud CI/CD and MLOps pipelines, reducing the credential validity window by 99.997% when a 15-minute session is compared with a 365-day credential.

DEVSECOPS

MULTI-CLOUD

WORKLOAD IDENTITY

Presented by **Venkata Velavarthipati**

Affiliation: Independent Researcher

The Problem

Persistent Credentials Are a Liability



Multi-cloud pipelines routinely embed **long-lived service account keys** in automation: as environment variables, secret stores, or config files. Every persistent credential is a standing target.

Credential Sprawl

Keys duplicated across repos, CI runners, and container images.

Rotation Debt

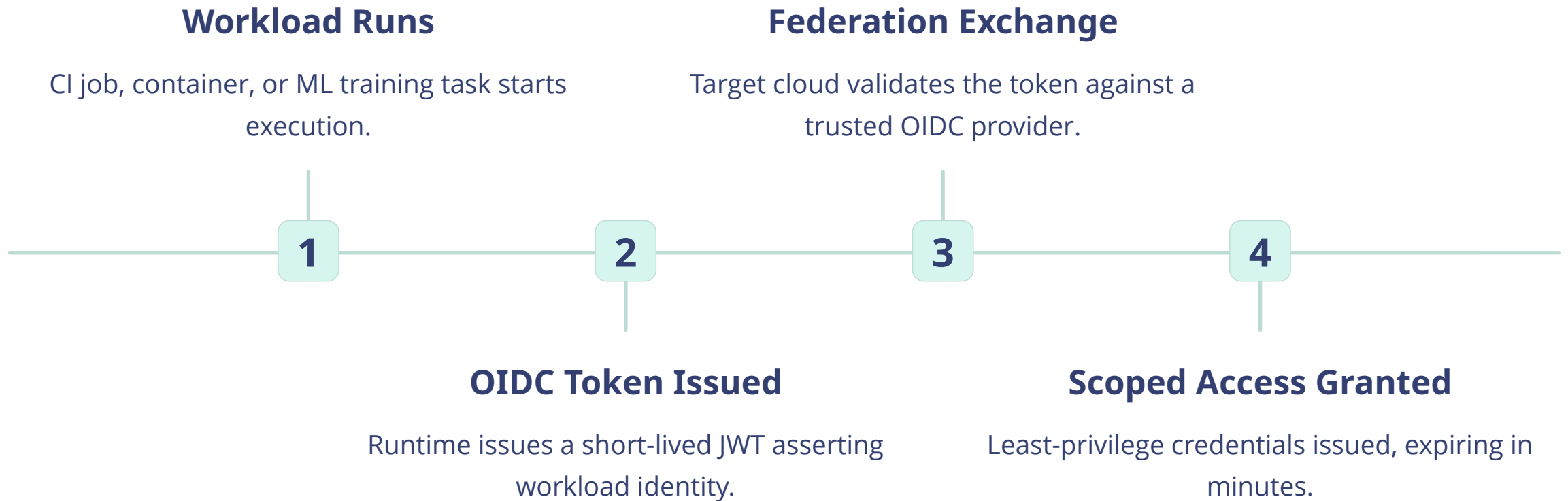
Infrequent rotation creates compounding exposure windows.

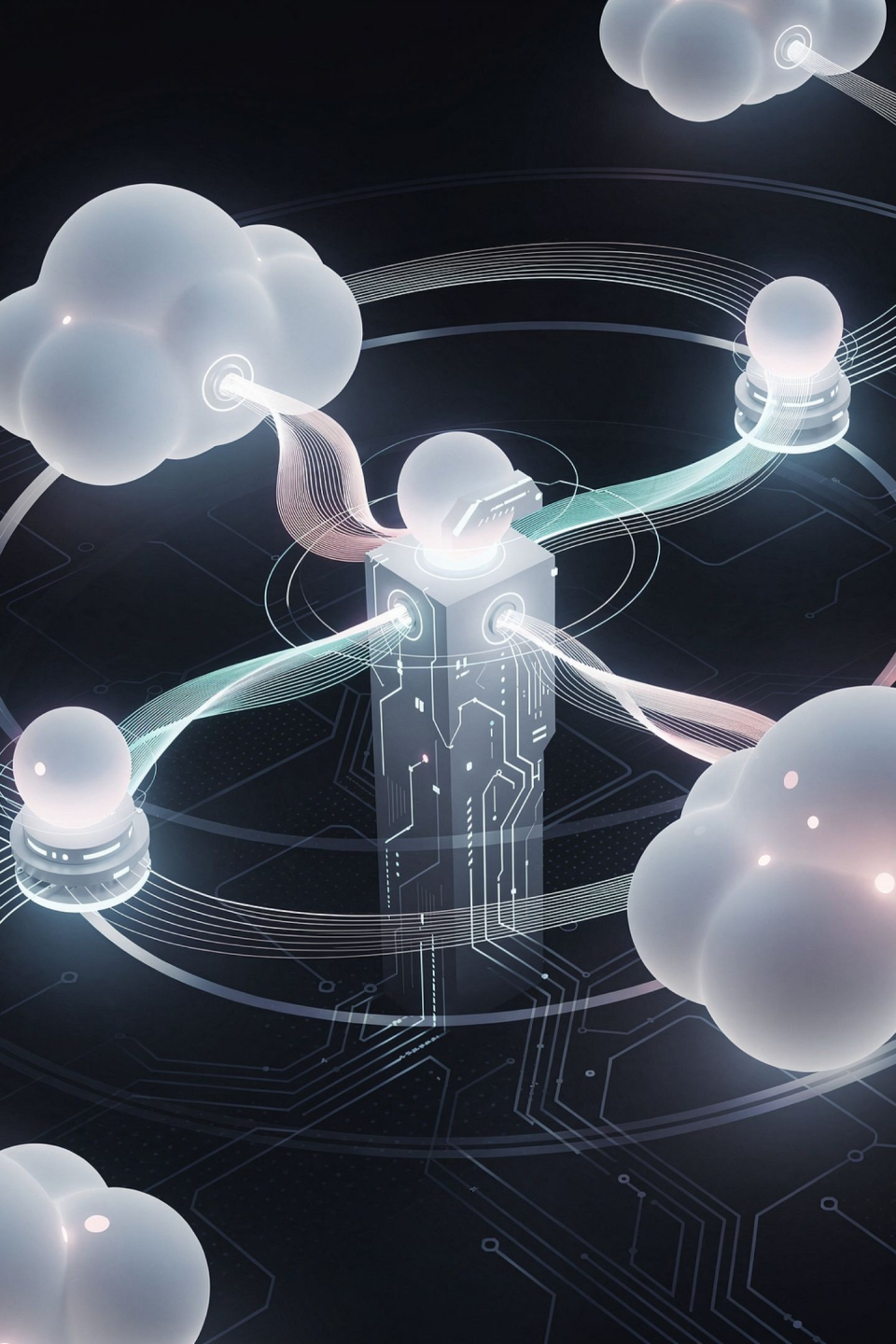
Cross-Cloud Gaps

Provider-native secrets don't span trust boundaries cleanly.

The Core Insight: Identity Over Credentials

Rather than issuing a key that a workload *possesses*, federated workload identity lets a workload *prove who it is*: at runtime, ephemeraly, with no secret to store or rotate.





OpenID Connect as the Trust Fabric

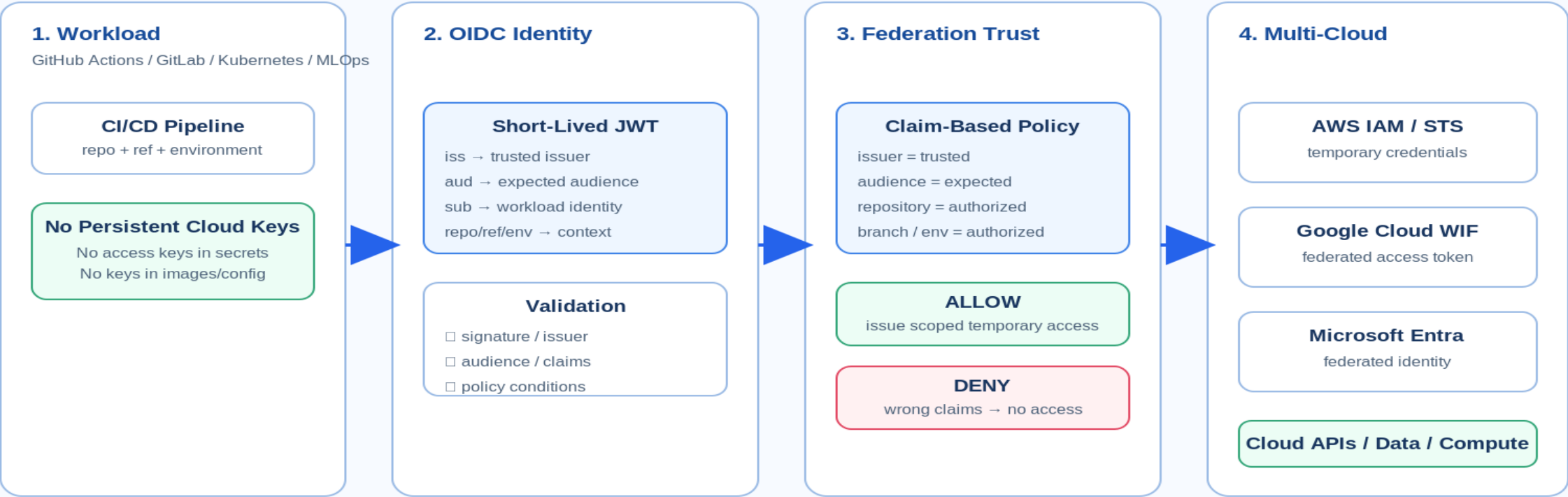
OIDC provides a vendor-neutral, cryptographically verifiable identity layer that all major cloud providers support as a federation endpoint, making it the ideal trust primitive for heterogeneous environments.

Architecture

Federated Identity Architecture

Secretless Multi-Cloud Authentication

OIDC workload identity federation for DevSecOps pipelines



Identity over Credentials

Audit trail: workload → token exchange → cloud API usage

Current executable proof: GitHub Actions OIDC → AWS IAM/STS → private S3. GCP/Azure are shown as the generalized multi-cloud target pattern.

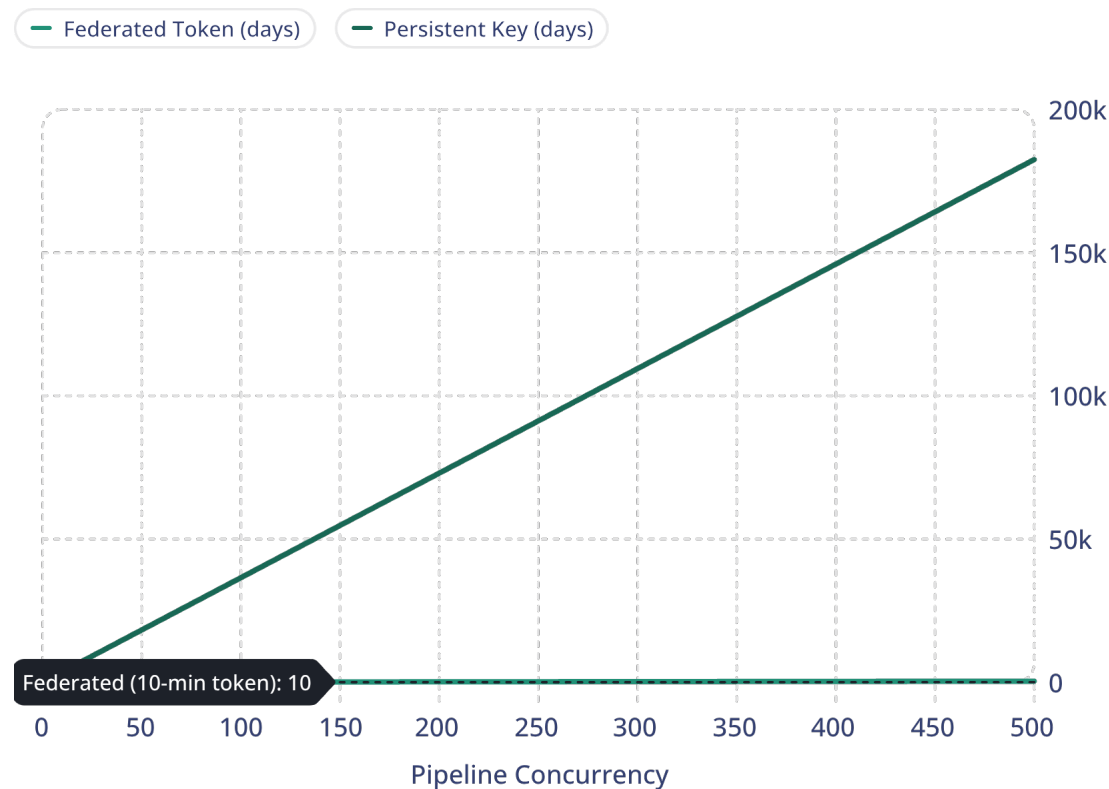
Threat Model

Quantifying the Credential Exposure Window

A simple exposure-window model treats credential exposure as proportional to pipeline concurrency × credential validity time. Replacing a 365-day credential with a 15-minute federated session reduces the validity window by 99.997%, before considering other controls.

$$V_{persistent} = N \times TTL_{key} \gg V_{federated} = N \times TTL_{token}$$

For a 15-minute session versus a 365-day credential: $1 - 15 / (365 \times 24 \times 60) = 99.997\%$ reduction in credential validity window. This is an exposure-window metric, not a breach-probability estimate.



Chapter 2

Pipeline Integration Patterns

Practical designs for embedding secretless auth into event-driven CI/CD and MLOps workflows.

CI/CD Pipeline: Secretless by Default



Every job boundary is a natural credential expiry point. No rotation scripts. No secret scanning exceptions. The pipeline *is* the identity context.

MLOps Data Ingestion: Scoped Cross-Cloud Pattern



The MLOps Challenge

Training jobs ingest data from heterogeneous sources, including object stores across AWS, GCP, and Azure, at high throughput. Persistent credentials embedded in training containers are a top exfiltration vector. Reference pattern: federated workload identity can issue per-job, per-dataset scoped access, decoupling data access from long-lived service accounts. This deck does not claim a measured cross-cloud MLOps latency result; latency should be reported only from captured runs.

Least-Privilege at the Claim Level



Environment Gating

TTL Enforcement

The AWS proof caps the IAM role session at 900 seconds. The workload receives temporary credentials rather than a long-lived cloud key.

Chapter 3

Operational Controls

Observability, failure handling, and trust lifecycle management in production environments.

Observability & Audit: Making Identity Visible

What to Instrument

1 Token Exchange Logs

Instrument the federation boundary with issuer/audience/claim context and STS responses where the platform exposes them; use CloudTrail to verify role-session activity.

2 Credential Usage Traces

Correlate short-lived role sessions with the originating pipeline run ID/session name to build provenance.

3 Anomaly Signals

Alert on unusual claim combinations, off-hours token requests, or unexpected source IP ranges.



Failure Modes & Resilience Design

Secretless authentication introduces new failure surfaces that must be handled gracefully in high-throughput pipelines.

STS Latency Spikes

Implement token caching within TTL bounds. Re-use within-job tokens; do not re-exchange on every API call.

OIDC Provider Outage

Design pipelines to fail-closed, with no fallback to static credentials. Alert immediately; don't silently degrade to long-lived keys.

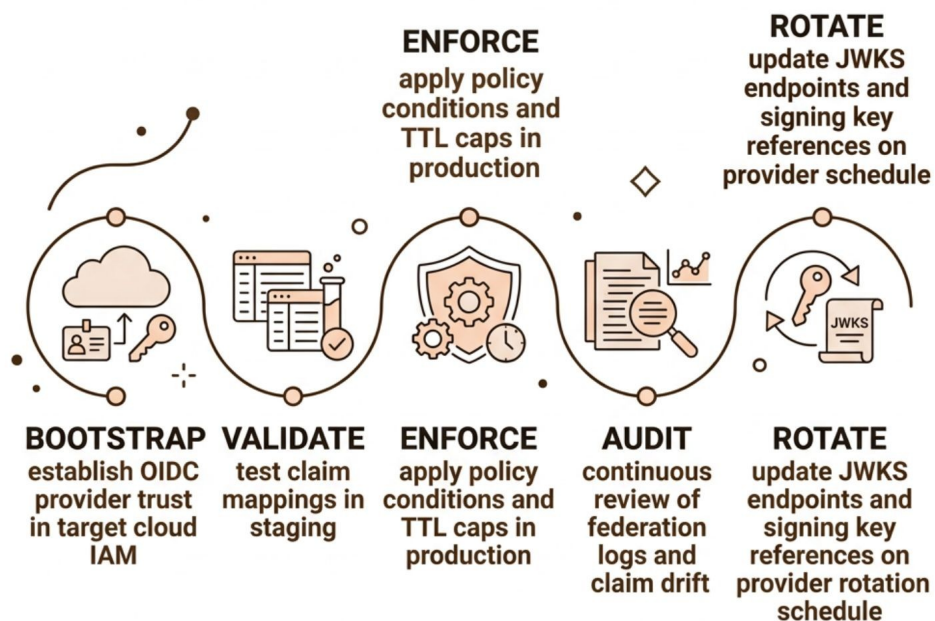
Clock Skew

Enforce NTP synchronization on all runners. JWT validation is time-sensitive; skew beyond provider tolerance causes silent auth failures.

Policy Misconfiguration

Test claim bindings in dry-run mode before production rollout. Overly broad conditions defeat the least-privilege intent of the architecture.

Trust Lifecycle Management



Treat Trust as Code

The repository behind this presentation contains the Terraform infrastructure and GitHub Actions workflow that implement the AWS proof.

The implementation establishes GitHub as the OIDC identity provider, validates the issuer, audience, repository, and environment claims, and maps the trusted identity to a least-privilege AWS IAM role.

STS then provides temporary credentials for the workload to access the dedicated private S3 resource.

The important implementation detail is that the workflow does not require a long-lived AWS access key.

The repository is provided as the reproducibility artifact; this presentation focuses on the architecture and security model rather than a live code demonstration.

Key Takeaways

01

Eliminate Persistent Keys

OIDC + workload identity federation removes the need for long-lived cloud credentials in the federated automation path.

02

Enforce at the Claim Level

Bind IAM trust to workload context: issuer, audience, repository, and environment in the current AWS proof.

03

Design for Failure-Closed

No graceful fallback to static credentials. Observability and alerting are non-negotiable.

04

99.997% Credential Validity-Window Reduction

A 15-minute federated session versus a 365-day credential produces a 99.997% reduction in credential validity window; this does not claim a 99.997% reduction in breach probability.

05

Security Without Friction

The goal is to keep authentication transparent to application code while enforcing trust and authorization at the platform layer.

Don't Distribute Credentials When You Can Establish Identity

Workload identity enables secure, scalable, and auditable access
across cloud environments without long-lived secrets.

- **Stronger Security**
Eliminate long-lived cloud credentials from pipelines.
- **Claim-Level Trust**
Bind access to issuer, audience, repository, and environment.
- **Short-Lived Access**
Use temporary credentials with bounded validity.
- **Multi-Cloud Pattern**
Apply federation across AWS, GCP, and Azure.
- **Reproducible Implementation**
Terraform + GitHub Actions implementation in the repository.

GitHub Repository

Scan to explore the project



github.com/vvelavarthipati/secretless-multi-cloud

"Don't distribute credentials when you can establish identity."